



ZAP Scanning Report

Sites: <https://content-signature-2.cdn.mozilla.net> <https://firefox-settings-attachments.cdn.mozilla.net> <https://www.newcoworker.com>

Generated on Wed, 15 Jul 2026 19:31:18

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	7
Low	7
Informational	13
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	25
Low	Exceeded High	https://www.newcoworker.com	Percentage of slow responses	86 %
Info	Informational	https://content-signature-2.cdn.mozilla.net	Percentage of endpoints with content type binary/octet-stream	100 %
Info	Informational	https://content-signature-2.cdn.mozilla.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://content-signature-2.cdn.mozilla.net	Count of total endpoints	1
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with content type application/octet-stream	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Count of total endpoints	1
Info	Informational	https://www.newcoworker.com	Percentage of responses with status code 2xx	61 %

Info	Informational	https://www.newcoworker.com	Percentage of responses with status code 3xx	38 %
Info	Informational	https://www.newcoworker.com	Percentage of responses with status code 4xx	1 %
Info	Informational	https://www.newcoworker.com	Percentage of endpoints with content type application/javascript	28 %
Info	Informational	https://www.newcoworker.com	Percentage of endpoints with content type application/xml	1 %
Info	Informational	https://www.newcoworker.com	Percentage of endpoints with content type image/png	2 %
Info	Informational	https://www.newcoworker.com	Percentage of endpoints with content type text/css	3 %
Info	Informational	https://www.newcoworker.com	Percentage of endpoints with content type text/html	43 %
Info	Informational	https://www.newcoworker.com	Percentage of endpoints with content type text/plain	4 %
Info	Informational	https://www.newcoworker.com	Percentage of endpoints with content type text/x-component	17 %
Info	Informational	https://www.newcoworker.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://www.newcoworker.com	Count of total endpoints	92

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
CSP: Failure to Define Directive with No Fallback	Medium	3
CSP: Wildcard Directive	Medium	3
CSP: script-src unsafe-inline	Medium	3
CSP: style-src unsafe-inline	Medium	3
Content Security Policy (CSP) Header Not Set	Medium	1
Cross-Domain Misconfiguration	Medium	Systemic
Sub Resource Integrity Attribute Missing	Medium	1
Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	5
Cross-Origin-Opener-Policy Header Missing or Invalid	Low	5
Cross-Origin-Resource-Policy Header Missing or Invalid	Low	1
Permissions Policy Header Not Set	Low	3
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	Systemic
Strict-Transport-Security Header Not Set	Low	Systemic
X-Content-Type-Options Header Missing	Low	4

Base64 Disclosure	Informational	12
Information Disclosure - Sensitive Information in URL	Informational	2
Information Disclosure - Suspicious Comments	Informational	2
Modern Web Application	Informational	Systemic
Re-examine Cache-control Directives	Informational	Systemic
Retrieved from Cache	Informational	Systemic
Sec-Fetch-Dest Header is Missing	Informational	3
Sec-Fetch-Mode Header is Missing	Informational	3
Sec-Fetch-Site Header is Missing	Informational	3
Sec-Fetch-User Header is Missing	Informational	3
Storable and Cacheable Content	Informational	2
Storable but Non-Cacheable Content	Informational	Systemic
User Controllable HTML Element Attribute (Potential XSS)	Informational	2

Alert Detail

Medium	CSP: Failure to Define Directive with No Fallback
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	https://www.newcoworker.com
Node Name	https://www.newcoworker.com
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	The directive(s): form-action is/are among the directives that do not fallback to default-src.
URL	https://www.newcoworker.com/api
Node Name	https://www.newcoworker.com/api
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	The directive(s): form-action is/are among the directives that do not fallback to default-src.
URL	https://www.newcoworker.com/privacy
Node Name	https://www.newcoworker.com/privacy
Method	GET
Parameter	Content-Security-Policy
Attack	

Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	The directive(s): form-action is/are among the directives that do not fallback to default-src.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: Wildcard Directive
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://www.newcoworker.com
Node Name	https://www.newcoworker.com
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, manifest-src, worker-src
URL	https://www.newcoworker.com/api
Node Name	https://www.newcoworker.com/api
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, manifest-src, worker-src
URL	https://www.newcoworker.com/privacy
Node Name	https://www.newcoworker.com/privacy

Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, manifest-src, worker-src
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: script-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://www.newcoworker.com
Node Name	https://www.newcoworker.com
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	script-src includes unsafe-inline.
URL	https://www.newcoworker.com/api
Node Name	https://www.newcoworker.com/api
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	script-src includes unsafe-inline.
URL	https://www.newcoworker.com/privacy

Node Name	https://www.newcoworker.com/privacy
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	script-src includes unsafe-inline.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: style-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://www.newcoworker.com
Node Name	https://www.newcoworker.com
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	style-src includes unsafe-inline.
URL	https://www.newcoworker.com/api
Node Name	https://www.newcoworker.com/api
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	style-src includes unsafe-inline.
URL	https://www.newcoworker.com/privacy
Node Name	https://www.newcoworker.com/privacy

Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'; base-uri 'self'; object-src 'none'
Other Info	style-src includes unsafe-inline.
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://www.newcoworker.com/cdn-cgi/l/email-protection
Node Name	https://www.newcoworker.com/cdn-cgi/l/email-protection
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Cross-Domain Misconfiguration
--------	-------------------------------

Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	https://www.newcoworker.com/_next/static/chunks/37v5ulr6qjozi.js?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr
Node Name	https://www.newcoworker.com/_next/static/chunks/37v5ulr6qjozi.js (dpl)
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://www.newcoworker.com/api
Node Name	https://www.newcoworker.com/api
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://www.newcoworker.com/llms.txt
Node Name	https://www.newcoworker.com/llms.txt
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://www.newcoworker.com/privacy
Node Name	https://www.newcoworker.com/privacy
Method	GET
Parameter	

Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://www.newcoworker.com/sitemap.xml
Node Name	https://www.newcoworker.com/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	Systemic
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	https://www.newcoworker.com/widget.js
Node Name	https://www.newcoworker.com/widget.js
Method	GET
Parameter	
Attack	
Evidence	<script src="https://newcoworker.com/widget.js" data-key="ncw_pub_..." async></script>
Other Info	
Instances	1
Solution	Provide a valid integrity attribute to the tag.

Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Low	Cross-Origin-Embedder-Policy Header Missing or Invalid
Description	Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).
URL	https://www.newcoworker.com
Node Name	https://www.newcoworker.com
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/
Node Name	https://www.newcoworker.com/
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/login
Node Name	https://www.newcoworker.com/login
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/privacy
Node Name	https://www.newcoworker.com/privacy
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/sitemap.xml

Node Name	https://www.newcoworker.com/sitemap.xml
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
Instances	5
Solution	Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Cross-Origin-Opener-Policy Header Missing or Invalid
Description	Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.
URL	https://www.newcoworker.com
Node Name	https://www.newcoworker.com
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/
Node Name	https://www.newcoworker.com/
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/login
Node Name	https://www.newcoworker.com/login
Method	GET

Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/privacy
Node Name	https://www.newcoworker.com/privacy
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/sitemap.xml
Node Name	https://www.newcoworker.com/sitemap.xml
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
Instances	5
Solution	Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Cross-Origin-Resource-Policy Header Missing or Invalid
Description	Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.
URL	https://www.newcoworker.com/robots.txt
Node Name	https://www.newcoworker.com/robots.txt
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	

Evidence	
Other Info	
Instances	1
Solution	Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages. 'same-site' is considered as less secured and should be avoided. If resources must be shared, set the header to 'cross-origin'. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Permissions Policy Header Not Set
Description	Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.
URL	https://www.newcoworker.com/69fb912ec929f017/script.js
Node Name	https://www.newcoworker.com/69fb912ec929f017/script.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/cdn-cgi/l/email-protection
Node Name	https://www.newcoworker.com/cdn-cgi/l/email-protection
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/cdn-cgi/scripts/5c5dd728/cloudflare-static/email-decode.min.js
Node Name	https://www.newcoworker.com/cdn-cgi/scripts/5c5dd728/cloudflare-static/email-decode.min.js
Method	GET

Parameter	
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy https://developer.chrome.com/blog/feature-policy/ https://scotthelme.co.uk/a-new-security-header-feature-policy/ https://w3c.github.io/webappsec-feature-policy/ https://www.smashingmagazine.com/2018/12/feature-policy/
CWE Id	693
WASC Id	15
Plugin Id	10063

Low	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	https://www.newcoworker.com/admin/login?next=%2Fadmin
Node Name	https://www.newcoworker.com/admin/login (next)
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
URL	https://www.newcoworker.com/contact
Node Name	https://www.newcoworker.com/contact
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
URL	https://www.newcoworker.com/contact?topic=white-glove
Node Name	https://www.newcoworker.com/contact (topic)
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: Next.js

Other Info	
URL	https://www.newcoworker.com/onboard
Node Name	https://www.newcoworker.com/onboard
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
URL	https://www.newcoworker.com/onboard/questionnaire?period=biennial&tier=standard
Node Name	https://www.newcoworker.com/onboard/questionnaire (period,tier)
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: Next.js
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://www.newcoworker.com/cdn-cgi/l/email-protection
Node Name	https://www.newcoworker.com/cdn-cgi/l/email-protection
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/cdn-cgi/scripts/5c5dd728/cloudflare-static/email-decode.min.js
Node Name	https://www.newcoworker.com/cdn-cgi/scripts/5c5dd728/cloudflare-static/email-decode.min.js

Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/cdn-cgi/styles/cf.errors.css
Node Name	https://www.newcoworker.com/cdn-cgi/styles/cf.errors.css
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/cdn-cgi/styles/cf.errors.ie.css
Node Name	https://www.newcoworker.com/cdn-cgi/styles/cf.errors.ie.css
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/robots.txt
Node Name	https://www.newcoworker.com/robots.txt
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	X-Content-Type-Options Header Missing
-----	---------------------------------------

Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://www.newcoworker.com/69fb912ec929f017/script.js
Node Name	https://www.newcoworker.com/69fb912ec929f017/script.js
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://www.newcoworker.com/cdn-cgi/styles/cf.errors.css
Node Name	https://www.newcoworker.com/cdn-cgi/styles/cf.errors.css
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://www.newcoworker.com/cdn-cgi/styles/cf.errors.ie.css
Node Name	https://www.newcoworker.com/cdn-cgi/styles/cf.errors.ie.css
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://www.newcoworker.com/robots.txt
Node Name	https://www.newcoworker.com/robots.txt
Method	GET
Parameter	x-content-type-options
Attack	

Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	4
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Base64 Disclosure
Description	Base64 encoded data was disclosed by the application/web server. Note: in the interests of performance not all base64 strings in the response were analyzed individually, the entire response should be looked at by the analyst/security team/developer(s).
URL	https://www.newcoworker.com
Node Name	https://www.newcoworker.com
Method	GET
Parameter	
Attack	
Evidence	2B4I9tnyFHKsSQXUaSAzRJ2I9KEdhM1fCRshtLAje0g95CDYmaSRyHh
Other Info	
URL	https://www.newcoworker.com
Node Name	https://www.newcoworker.com
Method	GET
Parameter	
Attack	
Evidence	te9Me8pTxY9hjnn18y0obrATu3UUN5jYvPdyDC5R5o1Cg1Q9iZlwClcrTgEdWpR5Qy0qy4CshgrNt6TB
Other Info	
URL	https://www.newcoworker.com/
Node Name	https://www.newcoworker.com/
Method	GET

Parameter	
Attack	
Evidence	PAzwHR4UGubVKIfbaAYjCKBwqTi6HmzO
Other Info	< W h # p 8 l
URL	https://www.newcoworker.com/_next/static/chunks/37v5ulr6qjozi.js?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr
Node Name	https://www.newcoworker.com/_next/static/chunks/37v5ulr6qjozi.js (dpl)
Method	GET
Parameter	
Attack	
Evidence	2F0S6wi99z2okiBSun2a6v4wKZwKe6
Other Info	] = R } 0) {
URL	https://www.newcoworker.com/_next/static/chunks/3ikjoic3rq2a2.css?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr
Node Name	https://www.newcoworker.com/_next/static/chunks/3ikjoic3rq2a2.css (dpl)
Method	GET
Parameter	
Attack	
Evidence	CrkJghZieTBHIAEgxiDysBncDN4jRtgeOjYhO6uou1pNpcuvoF5V1i5
Other Info	by0G F :6!;ZM ^U.
URL	https://www.newcoworker.com/api
Node Name	https://www.newcoworker.com/api
Method	GET
Parameter	
Attack	
Evidence	pJF23PcuOBIM3FIHYBI6AhSKj3XjmAZP
Other Info	v .8 YG` z u O
URL	https://www.newcoworker.com/dashboard
Node Name	https://www.newcoworker.com/dashboard
Method	GET
Parameter	
Attack	
Evidence	2FwwxtEuOrMNH111qaodPo48bdVbPmGUr17hUuZIRncK1NqxAfcCumktGHEH3pJNmEcqSa99HS
Other Info	\0 .: Yu > < m [> a ^ R HFw i- q M G * I }

URL	https://www.newcoworker.com/llms.txt
Node Name	https://www.newcoworker.com/llms.txt
Method	GET
Parameter	
Attack	
Evidence	2FAWvcKqCydM43UbOndBSr1Gfxi9YSS
Other Info	⚡P ⚡^ 'L⚡u :wAJ⚡F ⚡a\$
URL	https://www.newcoworker.com/login
Node Name	https://www.newcoworker.com/login
Method	GET
Parameter	
Attack	
Evidence	WWz34I8MUliVVax9WLhVOm4bsOXOXr1SPhxyMtUkGNVROqcMeRKAZSYGdpjLABF6Uj7L1xdb NZGI8L0bWJdOxx57BB2
Other Info	YI⚡⚡_ RX⚡U⚡}X⚡U:n ⚡⚡⚡^⚡R> r2⚡\$ ⚡Q:⚡ y ⚡e& v⚡⚡ zR>⚡⚡ [5⚡⚡⚡ X⚡N⚡ {
URL	https://www.newcoworker.com/logo.png
Node Name	https://www.newcoworker.com/logo.png
Method	GET
Parameter	
Attack	
Evidence	J3jZUJw5znMVBSMIPs07UYEbzCaUvAKIEwtlybo
Other Info	'x⚡P⚡9⚡s #%>⚡;Q⚡ ⚡&⚡⚡ ⚡ HJ
URL	https://www.newcoworker.com/privacy
Node Name	https://www.newcoworker.com/privacy
Method	GET
Parameter	
Attack	
Evidence	JL2Ix1Dz7I6O6K2IkKnpCksxM9BknC
Other Info	\$⚡⚡⚡P⚡⚡^⚡ ⚡⚡⚡ K13⚡d⚡
URL	https://www.newcoworker.com/sitemap.xml
Node Name	https://www.newcoworker.com/sitemap.xml
Method	GET
Parameter	
Attack	

Evidence	2FKfmifg2CjYHJDlqok9kvmuX2CA0ppXihIKQn7RW9zTPbL6HiUkdTuvsnuTLwFOcb1k2CsnM8slslG
Other Info	ⓂRⓂ'ⓂⓂ(Ⓜ ⓂÖⓂ=ⓂⓂⓂ_`ⓂKⓂⓂ B~Ⓜ[ⓂⓂ=ⓂⓂ %\$u;ⓂⓂ{Ⓜ/ NqⓂdⓂ+'3ⓂⓂQ
Instances	12
Solution	Manually confirm that the Base64 data does not leak sensitive information, and that the data cannot be aggregated/used to exploit other vulnerabilities.
Reference	https://projects.webappsec.org/w/page/13246936/Information%20Leakage
CWE Id	319
WASC Id	13
Plugin Id	10094

Informational	Information Disclosure - Sensitive Information in URL
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and most organizational compliance policies. You can configure the list of strings for this check to add or remove values specific to your environment.
URL	https://www.newcoworker.com/contact?businessName=ZAP&email=zaproxy%40example.com&extra_field=ZAP&message=Zaproxy+alias+impedit+expedita+quisquam+pariat+exercitationem.+Nemo+rurum+eveniet+dolores+rem+quia+dignissimos.&name=ZAP&subject=Zaproxy+dolore+alias+impedit+expedita+quisquam
Node Name	https://www.newcoworker.com/contact (businessName,email,extra_field,message,name,subject)
Method	GET
Parameter	email
Attack	
Evidence	zaproxy@example.com
Other Info	The URL contains email address(es).
URL	https://www.newcoworker.com/contact?businessName=ZAP&email=zaproxy%40example.com&extra_field=ZAP&message=Zaproxy+alias+impedit+expedita+quisquam+pariat+exercitationem.+Nemo+rurum+eveniet+dolores+rem+quia+dignissimos.&name=ZAP&subject=Zaproxy+dolore+alias+impedit+expedita+quisquam.&topic=white-glove
Node Name	https://www.newcoworker.com/contact (businessName,email,extra_field,message,name,subject,topic)
Method	GET
Parameter	email
Attack	
Evidence	zaproxy@example.com
Other Info	The URL contains email address(es).
Instances	2
Solution	Do not pass sensitive information in URIs.
Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	https://www.newcoworker.com/widget.js
Node Name	https://www.newcoworker.com/widget.js
Method	GET
Parameter	
Attack	
Evidence	// later, without reloading
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "// later, without reloading the script. Hiding also closes the panel.", see evidence field for the suspicious comment/snippet.
URL	https://www.newcoworker.com/widget.js
Node Name	https://www.newcoworker.com/widget.js
Method	GET
Parameter	
Attack	
Evidence	idget/frame (served from the New Coworker or
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "/* * New Coworker website chat widget loader. * * Businesses embed ONE tag on their own site: * * <script src="https://n", see evidence field for the suspicious comment/snippet.
Instances	2
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	https://www.newcoworker.com/%2Flogo.png&w=32&q=75&dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fjMr
Node Name	https://www.newcoworker.com//logo.png&w=32&q=75&dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fjMr
Method	GET
Parameter	

Attack	
Evidence	<script src="/_next/static/chunks/1o-2yoyeefnvq.js?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.newcoworker.com/%2Flogo.png&w=48&q=75&dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr
Node Name	https://www.newcoworker.com//logo.png&w=48&q=75&dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/1o-2yoyeefnvq.js?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.newcoworker.com/%2Flogo.png&w=96&q=75&dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr
Node Name	https://www.newcoworker.com//logo.png&w=96&q=75&dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/1o-2yoyeefnvq.js?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.newcoworker.com/api
Node Name	https://www.newcoworker.com/api
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/1o-2yoyeefnvq.js?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr" async=""></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	https://www.newcoworker.com/login
Node Name	https://www.newcoworker.com/login
Method	GET
Parameter	
Attack	
Evidence	<script src="/_next/static/chunks/1o-2yoyeefnvq.js?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr" async=""></script>

Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://www.newcoworker.com
Node Name	https://www.newcoworker.com
Method	GET
Parameter	cache-control
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
URL	https://www.newcoworker.com/llms.txt
Node Name	https://www.newcoworker.com/llms.txt
Method	GET
Parameter	cache-control
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
URL	https://www.newcoworker.com/privacy
Node Name	https://www.newcoworker.com/privacy
Method	GET
Parameter	cache-control
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
URL	https://www.newcoworker.com/robots.txt
Node Name	https://www.newcoworker.com/robots.txt
Method	GET
Parameter	cache-control

Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/sitemap.xml
Node Name	https://www.newcoworker.com/sitemap.xml
Method	GET
Parameter	cache-control
Attack	
Evidence	public, max-age=0, must-revalidate
Other Info	
Instances	Systemic
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015

Informational	Retrieved from Cache
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://www.newcoworker.com/_next/static/chunks/37v5ulr6qjozi.js?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr
Node Name	https://www.newcoworker.com/_next/static/chunks/37v5ulr6qjozi.js (dpl)
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://www.newcoworker.com/api
Node Name	https://www.newcoworker.com/api
Method	GET
Parameter	
Attack	

Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://www.newcoworker.com/llms.txt
Node Name	https://www.newcoworker.com/llms.txt
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://www.newcoworker.com/privacy
Node Name	https://www.newcoworker.com/privacy
Method	GET
Parameter	
Attack	
Evidence	Age: 494
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://www.newcoworker.com/sitemap.xml
Node Name	https://www.newcoworker.com/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	Age: 0
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
Instances	Systemic
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050

Informational	Sec-Fetch-Dest Header is Missing
Description	Specifies how and where the data would be used. For instance, if the value is audio, then the requested resource must be audio data and not any other type of resource.
URL	https://www.newcoworker.com/admin
Node Name	https://www.newcoworker.com/admin
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/dashboard
Node Name	https://www.newcoworker.com/dashboard
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/llms.txt
Node Name	https://www.newcoworker.com/llms.txt
Method	GET
Parameter	Sec-Fetch-Dest
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Dest header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Dest
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Mode Header is Missing
Description	Allows to differentiate between requests for navigating between HTML pages and requests for loading resources like images, audio etc.
URL	https://www.newcoworker.com/admin
Node Name	https://www.newcoworker.com/admin
Method	GET
Parameter	Sec-Fetch-Mode

Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/dashboard
Node Name	https://www.newcoworker.com/dashboard
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/llms.txt
Node Name	https://www.newcoworker.com/llms.txt
Method	GET
Parameter	Sec-Fetch-Mode
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Mode header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Mode
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-Site Header is Missing
Description	Specifies the relationship between request initiator's origin and target's origin.
URL	https://www.newcoworker.com/admin
Node Name	https://www.newcoworker.com/admin
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/dashboard
Node Name	https://www.newcoworker.com/dashboard
Method	GET
Parameter	Sec-Fetch-Site

Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/llms.txt
Node Name	https://www.newcoworker.com/llms.txt
Method	GET
Parameter	Sec-Fetch-Site
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-Site header is included in request headers.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-Site
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Sec-Fetch-User Header is Missing
Description	Specifies if a navigation request was initiated by a user.
URL	https://www.newcoworker.com/admin
Node Name	https://www.newcoworker.com/admin
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/dashboard
Node Name	https://www.newcoworker.com/dashboard
Method	GET
Parameter	Sec-Fetch-User
Attack	
Evidence	
Other Info	
URL	https://www.newcoworker.com/llms.txt
Node Name	https://www.newcoworker.com/llms.txt
Method	GET
Parameter	Sec-Fetch-User

Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that Sec-Fetch-User header is included in user initiated requests.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Sec-Fetch-User
CWE Id	352
WASC Id	9
Plugin Id	90005

Informational	Storable and Cacheable Content
Description	The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://www.newcoworker.com/_next/static/chunks/37v5ulr6qjozi.js?dpl=dpl_95nEAKGv3SPXEgdmubwPYH2fpjMr
Node Name	https://www.newcoworker.com/_next/static/chunks/37v5ulr6qjozi.js (dpl)
Method	GET
Parameter	
Attack	
Evidence	max-age=31536000
Other Info	
URL	https://www.newcoworker.com/robots.txt
Node Name	https://www.newcoworker.com/robots.txt
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
Instances	2
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0

	This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Informational	Storable but Non-Cacheable Content
Description	The response contents are storable by caching components such as proxy servers, but will not be retrieved directly from the cache, without validating the request upstream, in response to similar requests from other users.
URL	https://www.newcoworker.com/admin
Node Name	https://www.newcoworker.com/admin
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
URL	https://www.newcoworker.com/api
Node Name	https://www.newcoworker.com/api
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
URL	https://www.newcoworker.com/dashboard
Node Name	https://www.newcoworker.com/dashboard
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
URL	https://www.newcoworker.com/llms.txt
Node Name	https://www.newcoworker.com/llms.txt
Method	GET
Parameter	
Attack	

Evidence	max-age=0
Other Info	
URL	https://www.newcoworker.com/sitemap.xml
Node Name	https://www.newcoworker.com/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	max-age=0
Other Info	
Instances	Systemic
Solution	
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Informational	User Controllable HTML Element Attribute (Potential XSS)
Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	https://www.newcoworker.com/contact?businessName=ZAP&email=zaproxy%40example.com&extra_field=ZAP&message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&name=ZAP&subject=Zaproxy+dolore+alias+impedit+expedita+quisquam.&topic=white-glove
Node Name	https://www.newcoworker.com/contact (businessName,email,extra_field,message,name,subject,topic)
Method	GET
Parameter	topic
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://www.newcoworker.com/contact?businessName=ZAP&email=zaproxy%40example.com&extra_field=ZAP&message=Zaproxy+alias+impedit+expedita+quisquam+pariatur+exercitationem.+Nemo+rerum+eveniet+dolores+rem+quia+dignissimos.&name=ZAP&subject=Zaproxy+dolore+alias+impedit+expedita+quisquam.&topic=white-glove appears to include user input in: a(n) [input] tag [value] attribute The user input found was:

	topic=white-glove The user-controlled value was: white-glove onboarding
URL	https://www.newcoworker.com/contact?topic=white-glove
Node Name	https://www.newcoworker.com/contact (topic)
Method	GET
Parameter	topic
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://www.newcoworker.com/contact?topic=white-glove appears to include user input in: a(n) [input] tag [value] attribute The user input found was: topic=white-glove The user-controlled value was: white-glove onboarding
Instances	2
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031

Sequence Details

With the associated active scan results.